



VULNERABILITY ASSESSMENT REPORT

Cyber Security Task 1

Target Website: <http://testphp.vulnweb.com>

Internship Program: Future Interns



Prepared by: Saghana K S

Date: 31/1/26

Introduction & Scope

Introduction

This vulnerability assessment was conducted as part of a cybersecurity internship task to identify basic security misconfigurations in a web application. The objective of this assessment was to observe and analyze the security posture of the target website using passive and manual techniques.

The assessment focused on identifying publicly visible security weaknesses without interacting with or exploiting the application, ensuring that no harm was caused to the target system.

Scope of Assessment

The scope of this assessment was limited to the publicly accessible components of the target website (<http://testphp.vulnweb.com>). The assessment focused on identifying common security misconfigurations such as missing HTTP security headers, use of insecure communication protocols (HTTP instead of HTTPS), and server information disclosure through HTTP response headers.

No automated scanning, exploitation, or intrusive testing techniques were performed during this assessment.

Assessment Methodology

The assessment was conducted using a manual and passive observation approach. Browser developer tools were used to inspect HTTP response headers, while visual inspection of the browser address bar was used to identify the absence of HTTPS. All findings were documented based on direct observation of publicly available information.

Tools & Methodology

Tools Used

The following tools were used during the vulnerability assessment to observe and analyze the security posture of the target web application:

- Web Browser Developer Tools – Used to inspect HTTP response headers and identify missing security headers and server information disclosure.
- Manual Observation – Used to verify the use of HTTP instead of HTTPS by visually inspecting the website URL and browser address bar.

Assessment Approach

The assessment was conducted using a passive and manual testing approach. Security observations were made by analyzing publicly visible information without interacting with or modifying the target system.

The focus was on identifying basic security misconfigurations, including missing HTTP security headers, lack of secure communication (HTTPS), and server information disclosure through HTTP headers.

Ethical Considerations

This vulnerability assessment was performed strictly for educational purposes as part of a cybersecurity internship task. No exploitation, intrusive testing, or automated scanning was performed.

All observations were limited to publicly accessible information to ensure the confidentiality, integrity, and availability of the target system were not impacted.

Finding 1: Missing HTTP Security Headers

Description

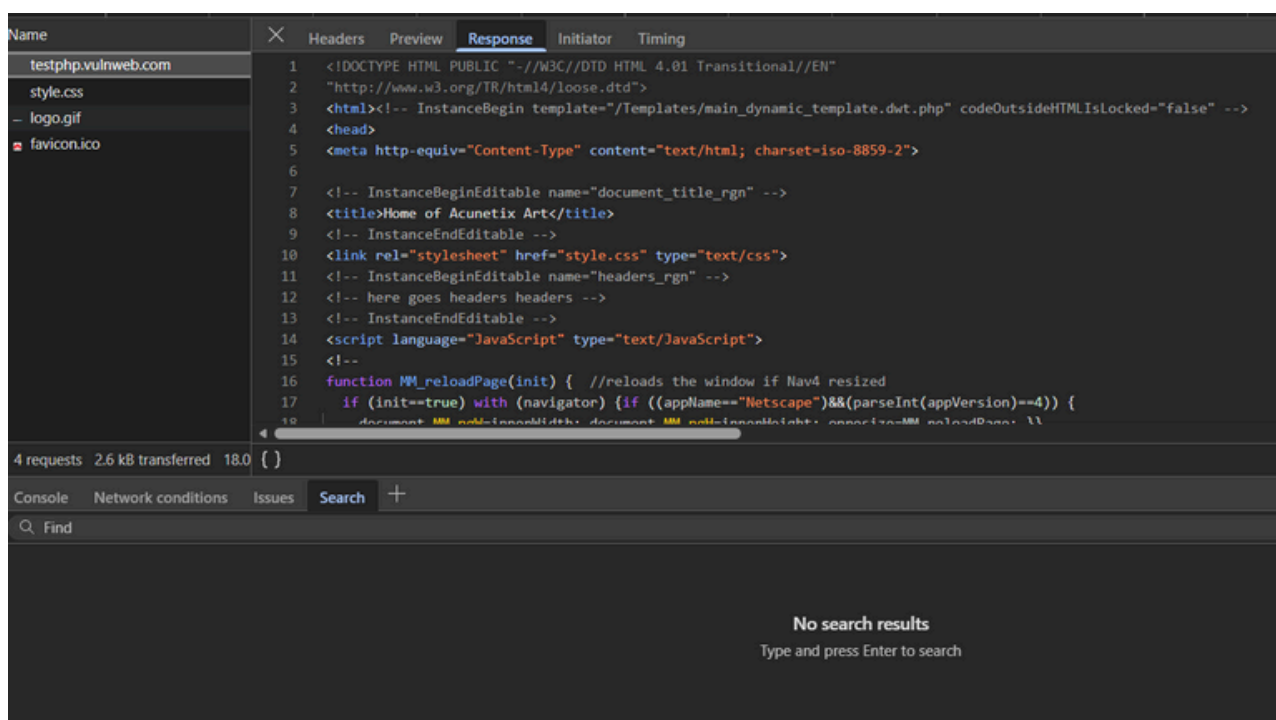
- HTTP security headers are used to instruct the browser on how to handle website content securely. During the assessment, it was observed that the target website does not implement several recommended HTTP security headers, which may expose the application to potential security risks.

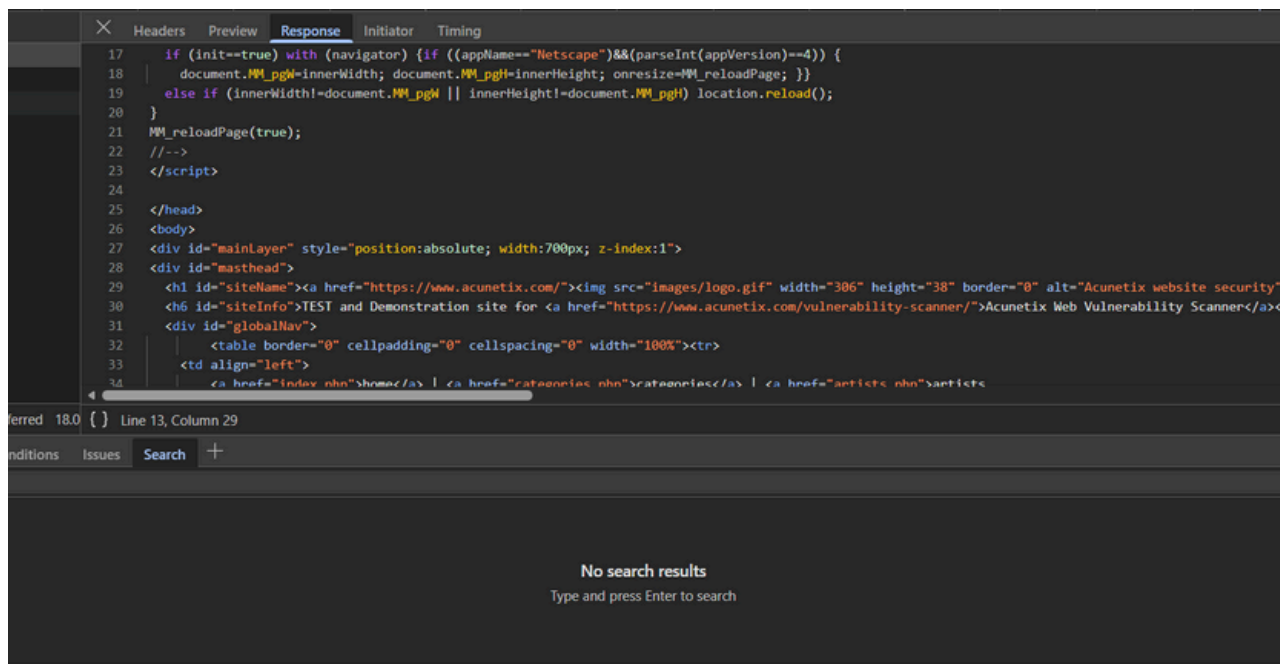
Evidence

The HTTP response headers were inspected using browser developer tools.

After refreshing the page in the Network tab and analyzing the response headers of the main request, it was observed that security headers such as X-Frame-Options, X-Content-Type-Options, and Content-Security-Policy were not present in the server response.

This confirms the absence of recommended HTTP security headers.





Risk Level

- Medium

Impact

The absence of HTTP security headers can increase the risk of client-side attacks such as clickjacking, cross-site scripting (XSS), and content-type sniffing. Attackers may exploit these weaknesses to manipulate user interactions or execute malicious scripts in the user's browser.

Recommended Remediation

It is recommended to implement appropriate HTTP security headers to enhance the security of the web application. Configuring headers such as X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, and Strict-Transport-Security can help mitigate these risks.

Finding 2: Unencrypted Communication (Missing HTTPS)

Description

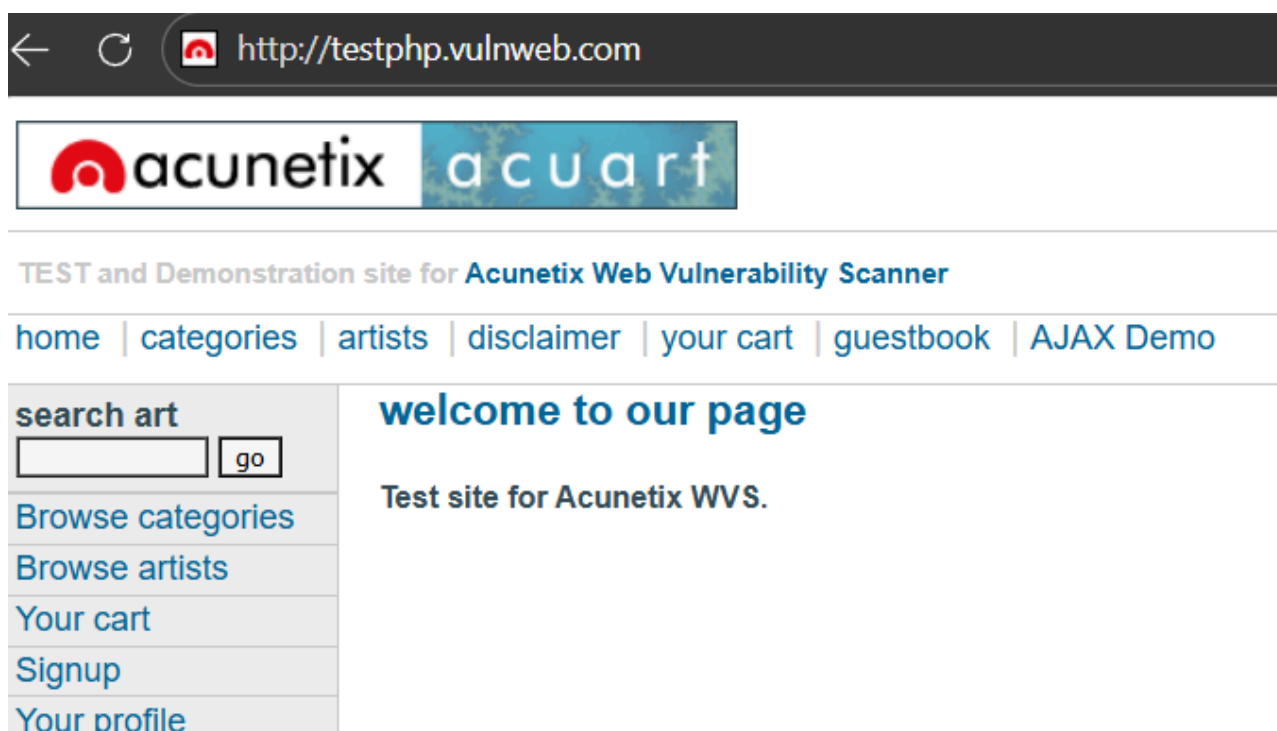
HTTPS is used to secure communication between a user's browser and the web server by encrypting data in transit.

During testing, it was observed that the target application is accessible over HTTP instead of HTTPS, meaning the data transmitted between the client and server is not encrypted.

This can expose sensitive information exchanged during user interactions to interception by attackers.

Evidence

Manual inspection was performed using the browser address bar and developer tools. The website was accessed using HTTP, and no automatic redirection to HTTPS was observed. This confirms that the application does not enforce secure communication.



Risk Level

- High

Impact

The absence of HTTPS can lead to:

- Interception of sensitive data (Man-in-the-Middle attacks)
- Exposure of login credentials and session data
- Loss of user trust due to "Not Secure" browser warnings
- Increased risk of data tampering during transmission

Recommended Remediation

It is recommended to:

- Implement HTTPS using a valid SSL/TLS certificate
- Redirect all HTTP traffic to HTTPS
- Enable HSTS (HTTP Strict Transport Security) to enforce secure connections
- Regularly monitor certificate validity and configuration

Finding 3: Information Disclosure via Client-Side Code

Description

Server and application information disclosure occurs when a web application reveals internal technical details that can help attackers understand how the system is built.

From the page source code, it was observed that the application exposes information about the technologies and structure used, including the document type, character encoding, scripting language, and external resources. Such disclosures can assist attackers in identifying potential weaknesses and planning targeted attacks.

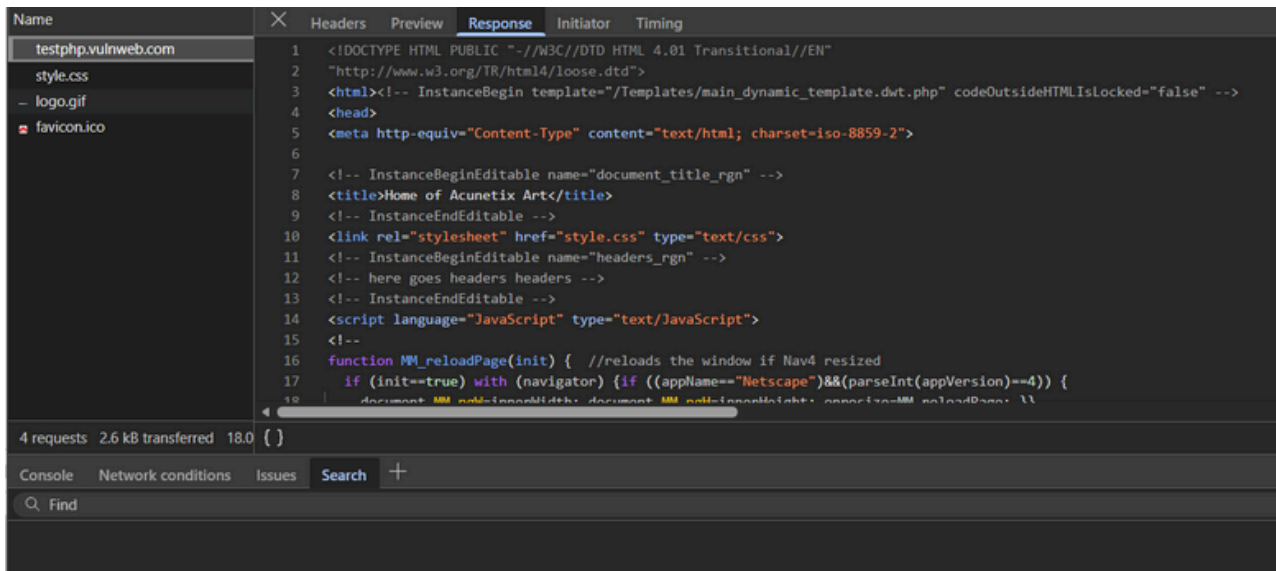
Evidence

Manual inspection of the page source was performed using the browser's Development tool.

The following information was observed in the HTML content:

- Use of HTML 4.01 Transitional document type
- Character encoding specified as iso-8859-2
- Presence of JavaScript functions and external script references
- References indicating a PHP-based application
- Explicit comments stating that the site is a test and demonstration application

This confirms that the application discloses implementation and technology-related details.



Risk Level

Low

Impact

Disclosure of server and application details may:

- Help attackers fingerprint the application and underlying technologies
- Assist in identifying known vulnerabilities related to disclosed technologies
- Reduce security by providing unnecessary information about application internals

Recommended Remediation

It is recommended to:

- Minimize unnecessary comments and metadata in production environments
- Avoid exposing implementation details in client-side code
- Use modern document standards and secure configurations
- Regularly review publicly accessible content for information disclosure